



Injection attack: a major threat against remote identity verification

IFPC 2025, 01/04/2025

*Cabinet of expertise
covering technologies, standards
and European policies*



*Technology Evaluation Laboratory
expert in
Digital Identities, Biometrics,
Mobile Security, Data Protection
and Cyber Security*

We are member of following associations :



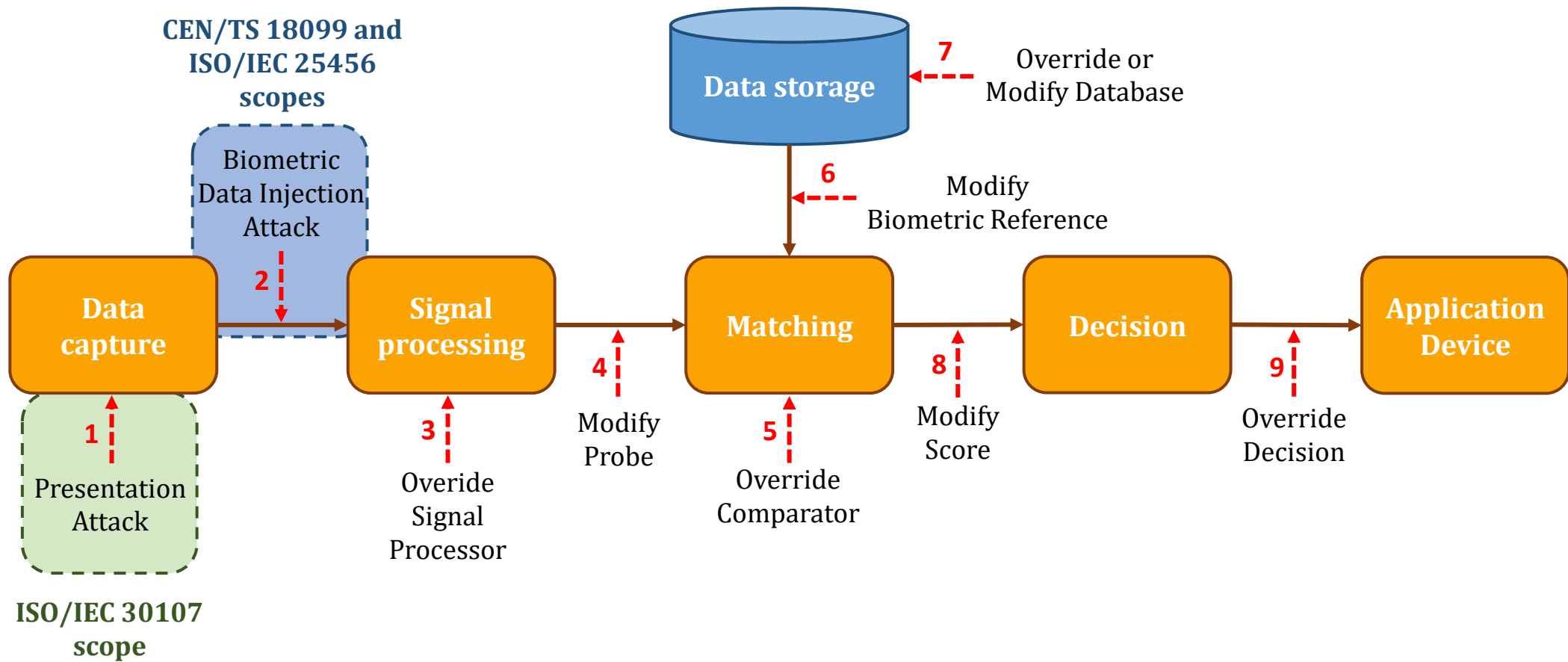
Quick presentation



Kévin Carta

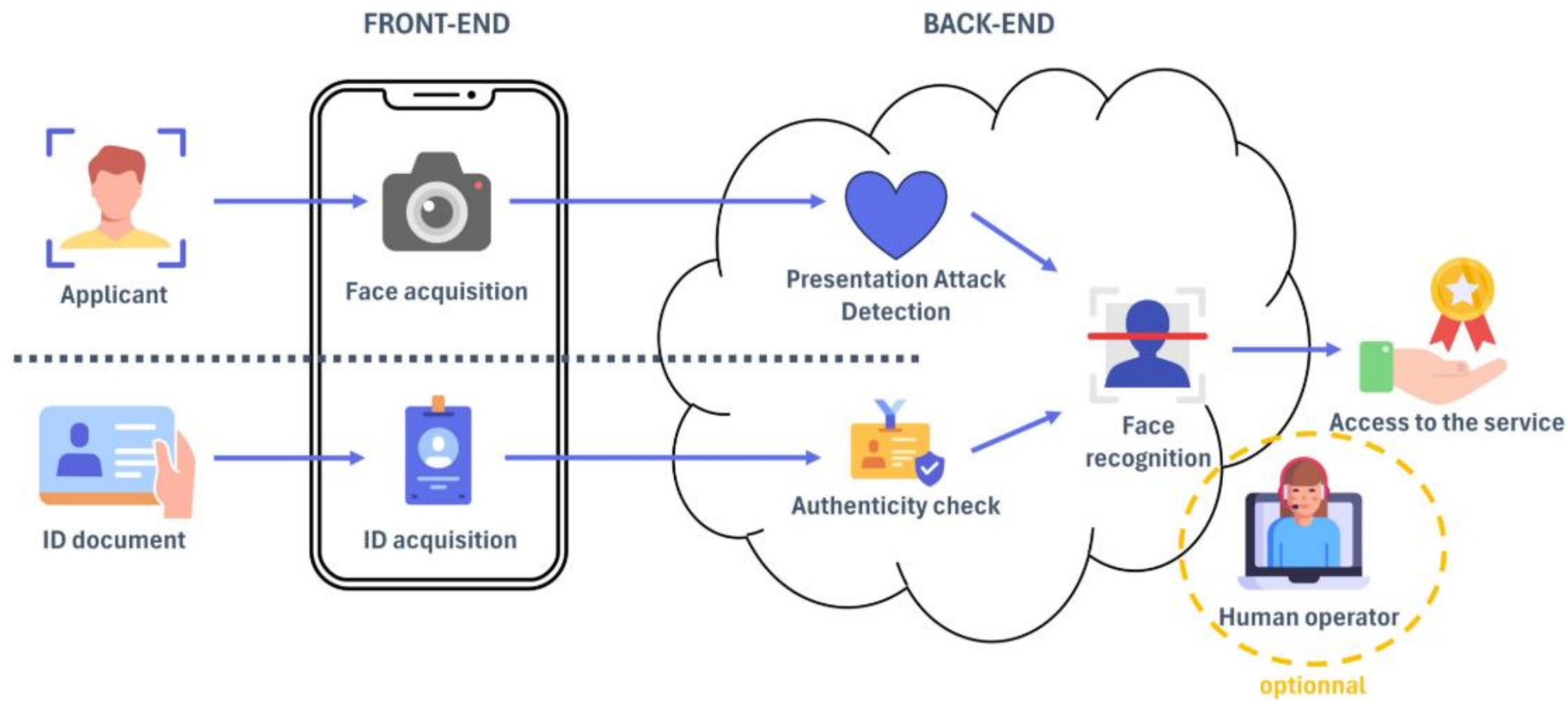
- **Director of CLR Labs** which provides evaluation services for **biometrics** (both PAD and IAD), **mobile application security**, **physical access control** and **cyber security**.
- **PhD** on the subject of injection attacks (PhD defense in October 2024) at Ecole des Mines de Saint-Etienne (France)
- **Editor of the CEN/TS 18099 and the future ISO/IEC 25456**

The standard's scope

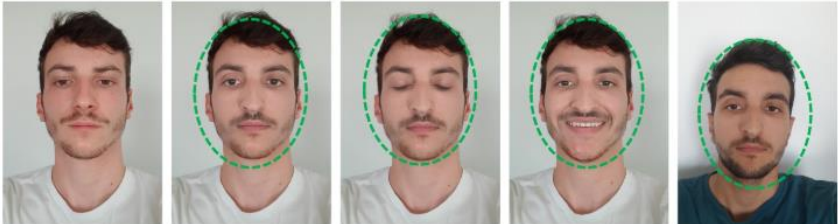
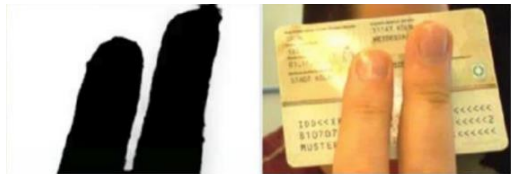


What are biometric data injection attacks ?

Remote identity proofing (RIDP)



Different types of frauds

	Biometrics	ID document
Physical	Mask Photo printed Screen 	Fake ID document Printed on paper Altered ID document 
Digital	Selfie Replay attack Morphing Deepfake 	Replay attack Video overlay Augmented reality overlay  Fg/bg segmentation result Hologram processing result

Problem of digital attacks (as an attacker)

How to present a digital attack to the system: With a screen?



Today: State-of-the-art liveness detection systems easily detect the presentation of screens

Ideal: Send the digital attack through a “fictitious” video stream.

- ⇒ No or little loss of image quality compared to the source media.
- ⇒ Bypassing screen detection: liveness detection is purely at the biometric level.

Solution: Injection attacks.



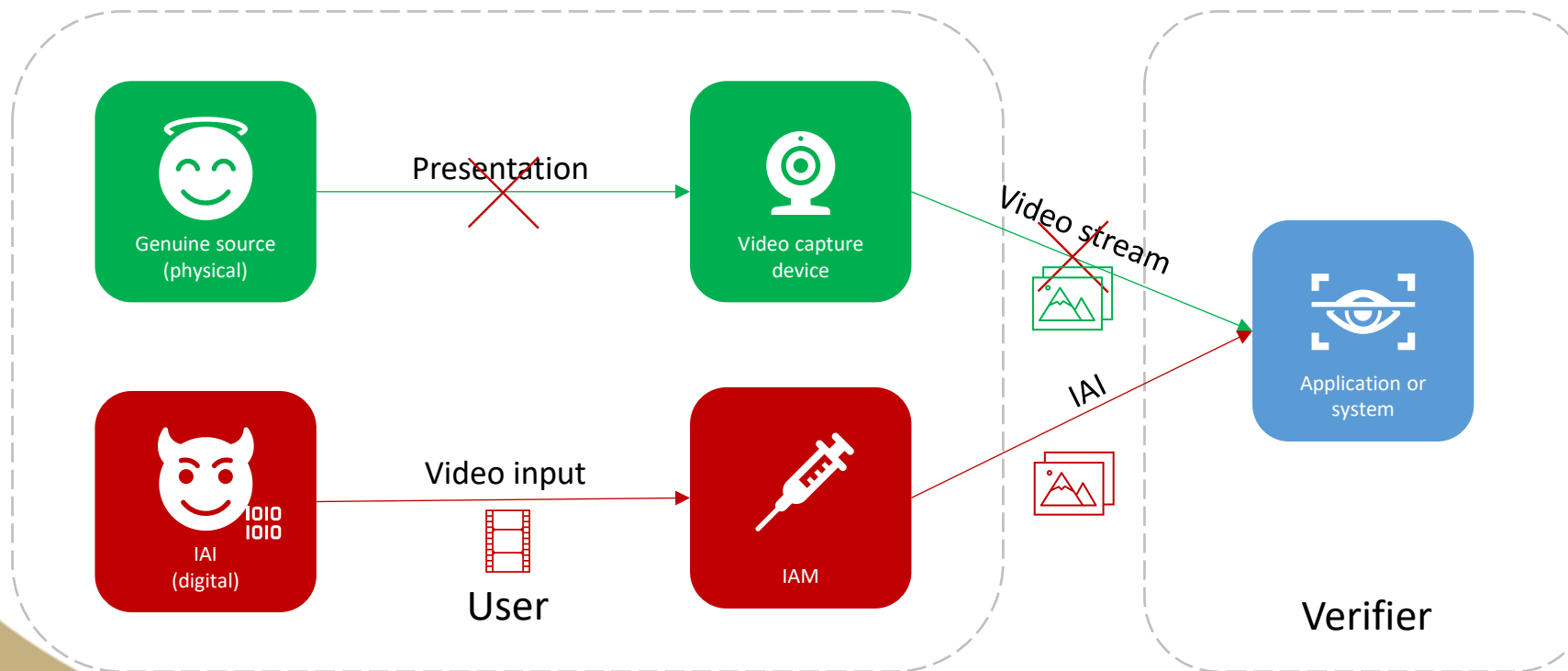
Video injection

Injection Attack Method - IAM: It exists several methods (cf. next slides).

Injection Attack Instrument – IAI: Set of images ↔ manipulated video.

Application or system: Web application, acquisition software, mobile application, etc.

Objective : Bypass security mechanisms.



Different types of IAMs

The use of modified or falsified camera.

It allows the attacker to inject an Injection Attack Instrument (IAI) using a tool or software that is perceived by the facial recognition system as a real camera.

Examples:

- Software virtual camera
- Hardware virtual camera
- External video capture card
- Mobile device emulator

Replacing the images captured by a real camera with attack images.

The images are replaced by an IAI during the transmission of authentic images to other modules of the facial recognition system

Examples:

- Function hooking process
- Man-in-the-Middle process

Different types of IAIs

Raw data

The attacker injects stolen raw data in order to fool the biometric system.

Examples:

- Replay attacks
- Editing attacks

Modified/alterd data

The attacker uses stolen biometric data and modifies it to fool the biometric system.

Examples:

- Face reenactment
- Morphed images
- Face swap

Synthetic data

The attacker can use artificially generated face data in order to conceal its own identity.

Examples:

- Synthetic images

Injection Attack Detection (IAD)

Injection Attack Method Defense Mechanism (IAMDM)

A defense mechanism aiming at making a biometric system resistant to injection attack methods.

Examples:

- Camera anti-tempering
- Session metadata analysis
- Code obfuscation
- Runtime Application Self Protection
- Mobile device emulator

Injection Attack Instrument Defense Mechanism (IAIDM)

A defense mechanism aiming at making a biometric system resistant to injection attack instruments.

Examples:

- Replay attack detection
- Automated artifact detection
- Procedural controls (randomness, human operators, etc.)

Why do we need a standard ?

The context

EU regulations

The AML 5 anti-money laundering regulation and the recent revision of eIDAS have accelerated the use of remote identity proofing solutions (RIDP).

This use mainly concerns sensitive services:

- Digital identity (governments)
- Banking services
- e-health services
- Insurance services

A new threat

Injection attacks are therefore a recent threat, having emerged with the use of remote biometrics, particularly in remote identity proofing services.

This threat is already a reality:

- 783% increase in injection attacks in 2024 (iProov)
- Injection attacks increased 200% in 2023 (Gartner)

PVID referential

The *Agence Nationale de la Sécurité des Systèmes d'Informations* (ANSSI), which is the French cybersecurity agency, has been the first agency to provide of a certification scheme for RIDP in 2021 with the *PVID referential*.

This certification scheme requires penetration testing on **presentation attacks, injection attacks and ID document fraud**.

A need for a standard on the subject

The arrival of the EUDI wallet

The need for a standard was quickly felt in order to explain the problem and enable manufacturers and academics to tackle the subject head on.

It also comes with the upcoming release of the EUDI wallet, where injection attacks represent a major threat of identity fraud during the citizen enrolment phase.

A need for European harmonisation

The standard will also make it possible to harmonise the various projects in Europe that deal in one way or another with injection attacks:

- French ANSSI (Agence Nationale de la Sécurité des Systèmes d'Information) in remote identity verification referential called P.V.I.D.
- European Standards Organization ETSI (European Telecommunications Standards Institute) in their TS 119 461 which deals with remote identity verification.
- European Union Agency for Cybersecurity (ENISA) in "Remote Identity Proofing: Attacks and Countermeasures" report.
- German BSI (Bundesamt für Sicherheit in der Informationstechnik) in the Technical Guideline TR-03147 Assurance Level Assessment of Procedures for Identity Verification of Natural Persons.
- Spanish CCN Security Guide for ITC products – Annex F.11: Videoidentification

The content of the CEN/TS 18099

Definition of the subject

Basically, this is all we have seen since now.

All the terms and definition we have used here (IAI, IAM, etc.) have been defined in the standard.

The standard have been created to **tackle different biometric modalities** even if for now face recognition is the major target. Indeed, injection attacks are also applicable on:

- Iris recognition
- Voice recognition
- Fingerprint recognition (when filmed through RGB camera)

A specific test plan

The standard provide a complete test methodology for the labs.

The methodology is based on the identification + exploitation phases. If an attack bypass the system, **it is identified**. If it can be reproduced, **the attack is exploited**. **Then the attack is rated** thanks to the attack rating methodology defined in the standard.

The test plan provides **3 different levels** (with different requirements on number of attacks, number of days of testing, etc.):

- Basic level
- Substantial level
- High level

Why do we need a standardised test plan?

Harmonisation between the labs

The main reason is to have a harmonisation on the work performed by the different laboratories that will provide conformance evaluations.

Indeed, without an evaluation methodology, the laboratories are free to develop their own test plan.

For security purposes

As we have seen, most of the services threatened by injection attacks are sensitive services.

The methodology provided in the standard is based on a deterministic approach to « ensure » that the system does not have any vulnerability.

Important note: a system unvulnerable does not exist.

Current state of the standard



- Project began in September 2021
- Standard published in November 2024.



- Mandatory testing in conformance with TS 18099 should be added in the next revision of ETSI TS 119 461 (October 2024)
- Could be referenced in the upcoming implementing acts for EUDI wallet



- Project began in January 2025
- Creation of a Joint Working Group between SC27 (Cybersecurity) and SC37 (Biometrics)

Questions ?

Our research papers on injection attacks

- **2024:** K. Carta, A. Huynh, S. Mouille and N. El Mrabet, *An Overview of Biometric Data Injection Attacks on Remote Identity Proofing Solutions*, SSRN (https://papers.ssrn.com/sol3/papers.cfm?abstract_id=4855561)
- **2023:** K. Carta, A. Huynh, S. Mouille, N. El Mrabet, S. Brangoulo and C. Barral, *How video injection attacks can even challenge state-of-the-art Face Presentation Attack Detection Systems*, IMCIC 2023- 14th International Multi-Conference on Complexity, Informatics and Cybernetics, DOI: 10.54808/ IMCIC2023.01.105
- **2022:** K. Carta, C. Barral, S. Mouille and N. El Mrabet, *Video injection attacks on remote digital identity verification solution using face recognition*, IMCIC 2022- 13th International Multi-Conference on Complexity, Informatics and Cybernetics, DOI: 10.54808/IMCIC2022.02.92
- **2021:** K. Carta, C. Barral, S. Mouille and N. El Mrabet, *On the pitfalls of video conferences for challenge based face liveness detection*, 25th World Multi-Conference on Systemics, Cybernetics and Informatics, WMSCI2021, ISBN:978-171383519-6

